MBA · Executive Program

Privacy-Preserving Machine Learning (PPML)

Federated Learning · Differential Privacy · Homomorphic Encryption · Multi-Party Computation

Privacy-Preserving Machine Learning — Principles, Cases, Regulation

How to train models without collecting, seeing, or memorizing the data.
One storyline covering how the techniques work, real deployments in Korea and abroad, and 2026 regulatory changes in Korea and the EU.

This lecture comes down to three messages

Judgment criteria to remember before any technique names

1

Removing names does not hide people

A few clues, links to other data, and model memory can single out an individual again.

2

PPML is a combination, not a single technique

Federated learning keeps data in place, DP limits memory, and cryptography hides computation.

3

Regulation shifted from prohibition to proof

Korea's AI special provision and the EU Digital Omnibus both allow use once safeguards are proven.

There is only one question — how do we guarantee that training on this data does not expose any specific individual?

Machine learning and privacy are structurally in conflict

The more data we collect, the better the model and the greater the risk

Good models need lots of data, but that data is scattered across institutions and devices, and it is sensitive

Two reasons data is hard to pool

- Cost: sending data from millions of devices to a server incurs heavy communication and storage costs
- Regulation: the Personal Information Protection Act and GDPR restrict moving medical, financial, and location data

Is deleting names enough?

- Pseudonymized data can be re-identified when combined with other information
- ZIP code, birth date, and sex alone single out 87% of Americans (PART 1)
- That is why the US Census Bureau adopted DP for the 2020 Census

The PPML discussion starts with five terms

Korean legal terms and technical terms side by side

Term	Meaning	Example
Personal information	Information that can identify a living individual	Name, account number, face image
Pseudonymized information	Information processed so that the person cannot be identified without additional information	Replacing customer IDs with serial numbers
Anonymized information	Information that cannot be re-identified by any means	Sufficiently aggregated statistics
PET	Privacy Enhancing Technologies (PET)	Synthetic data, DP, homomorphic encryption
PPML	Machine learning that applies PETs to training and inference	Federated learning + DP keyboard model

Pseudonymized information is still personal information. Only anonymized information falls outside the Personal Information Protection Act

01

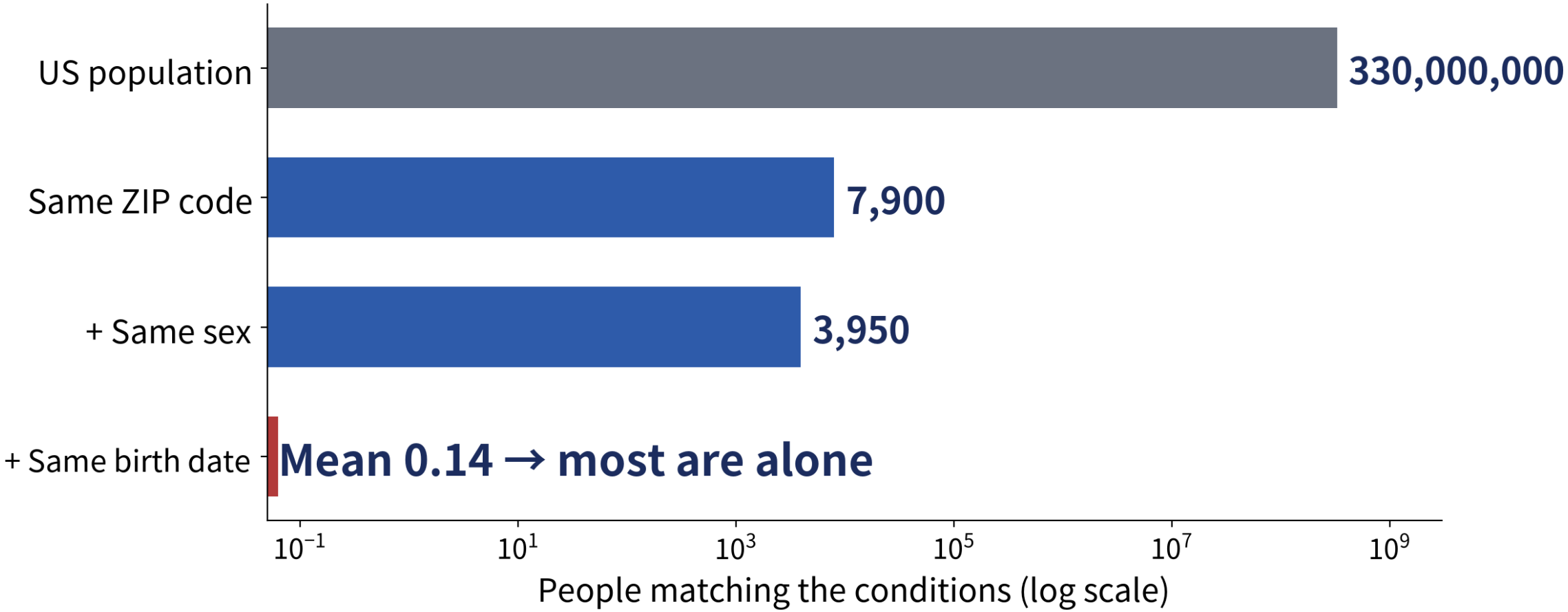
PART 1 · Re-identification

A few clues are enough to tell who someone is

De-identified data becomes people again when it meets other data

Keep just three fields and most people are alone

Sweeney (2000): ZIP code, birth date, and sex single out 87% of Americans



When there are more cells than people, almost everyone is alone

Assumption: birthdays spread evenly over 80 years. Korean figures are approximations using average population per administrative unit

$$\Pr[\text{alone}] \approx e^{-N/K}, \qquad N = \text{local population}, \quad K = \underbrace{365 \times 80}_{\text{birth date}} \times \underbrace{2}_{\text{sex}} = 58{,}400$$

87%

US · ZIP code average 7,900 people
Matches Sweeney's empirical figure

About 78%

Korea · eup/myeon/dong average about 15,000
(population 51.7 million ÷ about 3,500 units)

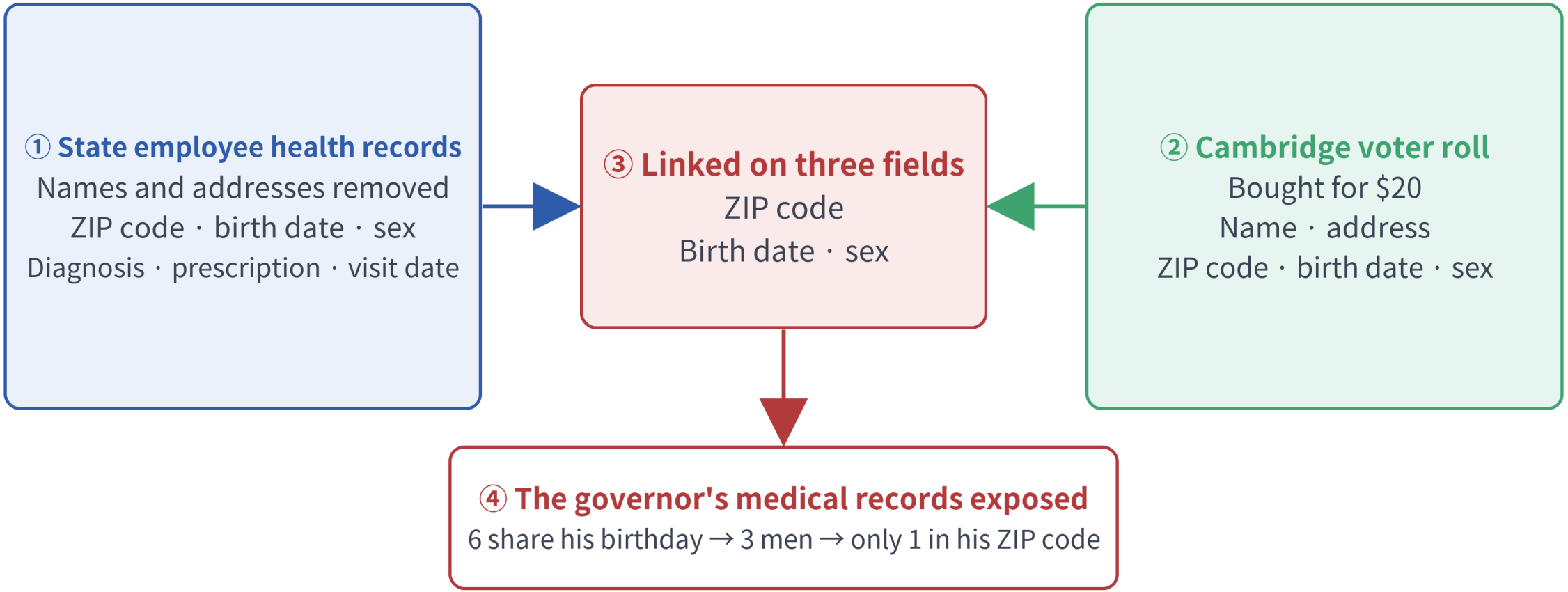
About 2%

Korea · si/gun/gu average about 230,000
Widening the region makes it rapidly safer

That is why pseudonymization commonly coarsens addresses to the si/gun/gu level and birth dates to birth year or age band

De-identified records were reopened with a $20 voter roll

1997 Massachusetts Group Insurance Commission (GIC) data — a linkage attack joining two datasets on shared fields

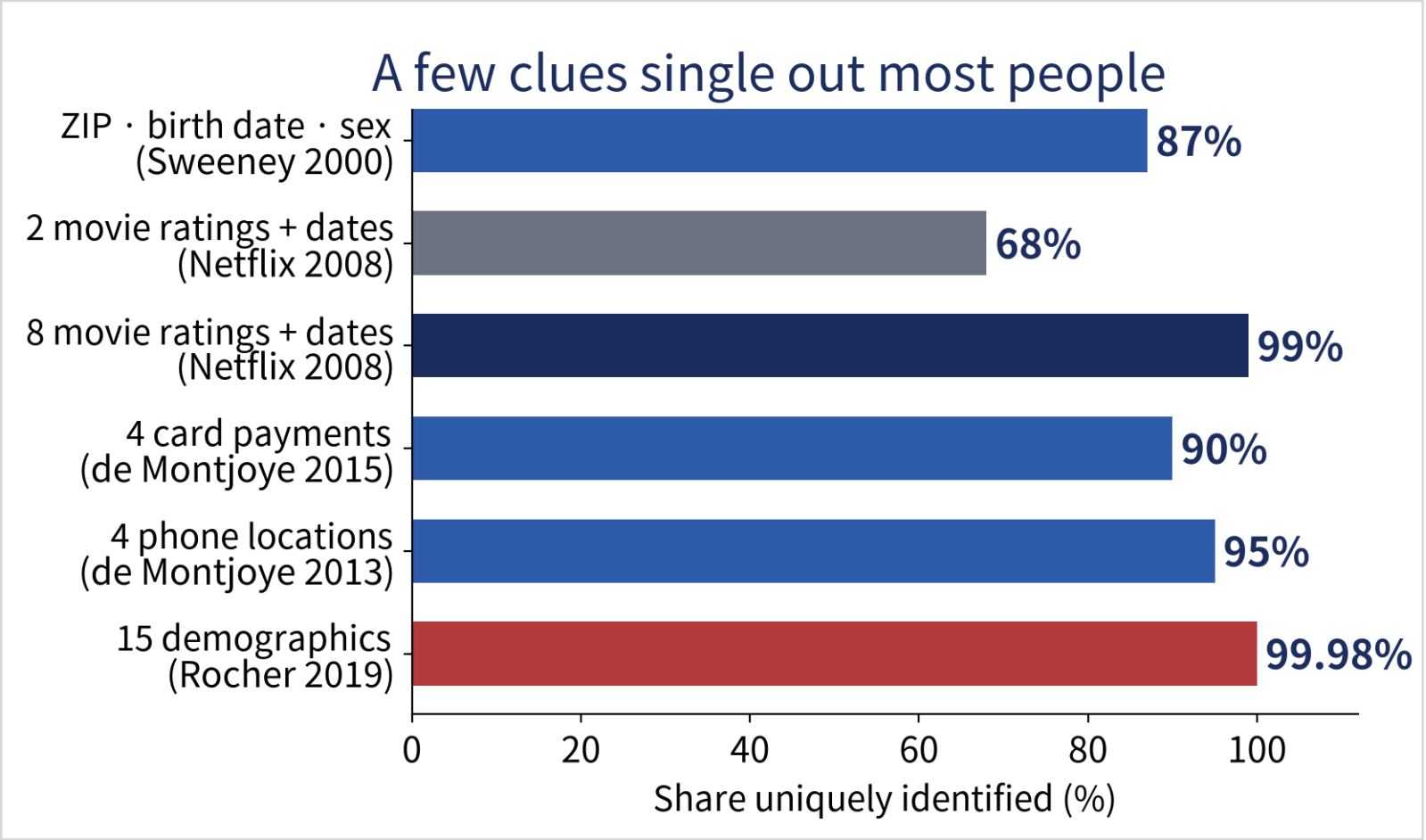


About four clues are enough to single out almost everyone

Sparse behavioral records such as ratings, payments, and locations differ from person to person like fingerprints

How to read it

- When and where is the fingerprint
- The sparser, the riskier
- Clues are easy to obtain



Four incidents where anonymously released data came back with real names

In every case, names and IDs had been removed or replaced before release

AOL search logs (2006)

- Released about 20 million search queries from 650,000 users, tagged only with numbers
- The New York Times identified user No. 4417749 as a 62-year-old woman

Netflix ratings (2006–2010)

- Movie ratings of 500,000 users were identified by matching them against public IMDb ratings
- After a lawsuit, the second competition was canceled in 2010

New York taxis (2014)

- Hashed taxi numbers in 173 million trip records were cracked within an hour by hashing every possible number
- Matching celebrity ride photos with time and place revealed destinations and fares

Strava exercise map (2018)

- Released a global heatmap aggregating users' running routes
- Outlines and patrol routes of overseas military bases became plainly visible

k-anonymity hides anyone among at least k people

Sweeney (2002). Quasi-identifiers such as age and address are coarsened (generalized) so that records share the same values

$$\min_{q} \left| \{ i \ : \ \textbf{quasi-identifier}_{\,i} = q \} \right| \ \geq \ k$$

(every combination has at least k people)

Original (names removed only)

Age	Dong	Sex	Default
34	Yeoksam 1-dong	M	Normal
36	Yeoksam 2-dong	M	Normal
52	Daechi 1-dong	F	Default
57	Daechi 4-dong	F	Default

After generalization (k = 2)

Age band	Area	Sex	Default
30s	Yeoksam	M	Normal
30s	Yeoksam	M	Normal
50s	Daechi	F	Default
50s	Daechi	F	Default

No one is singled out, yet if she is a woman in her 50s in Daechi, her default is still revealed

Anonymity cannot be judged from the data alone

The limits of k-anonymity lead to differential privacy (PART 3)

Anonymity is not a property of the data; it is set by the data's relationship to other data the attacker holds

What k-anonymity cannot stop

- Homogeneity attack: if everyone in a group defaulted, the default is revealed
- Background knowledge attack: once the attacker obtains new data, the standard collapses

Hence the new approach

- The law treats pseudonymized information as personal information and controls linking and export
- DP gives a guarantee that holds whatever the attacker knows

Trained models leak personal information through four channels

Attack types differ by what the attacker can access

Attack	What the attacker sees	What leaks
Membership inference	Model output probabilities	Whether a specific person was in the training data
Model inversion	Model outputs and some attributes	Sensitive attributes of individuals used in training
Gradient inversion	Gradients sent in federated learning	The training input images and sentences themselves
Training data extraction	Generative model responses	Verbatim text of training documents

The first two target classic classifiers; the last two are risks that grew with federated learning and generative AI

Even aligned commercial chatbots can spit out training text

Nasr et al. (ICLR 2025): extraction experiments on open, semi-open, and commercial models

Gigabytes

from public models such as Pythia and GPT-Neo of training data extracted

150×

increase in the rate at which ChatGPT emits training data under the divergence attack

Thousands

of commercial-model training examples recovered by defeating alignment

How to read it

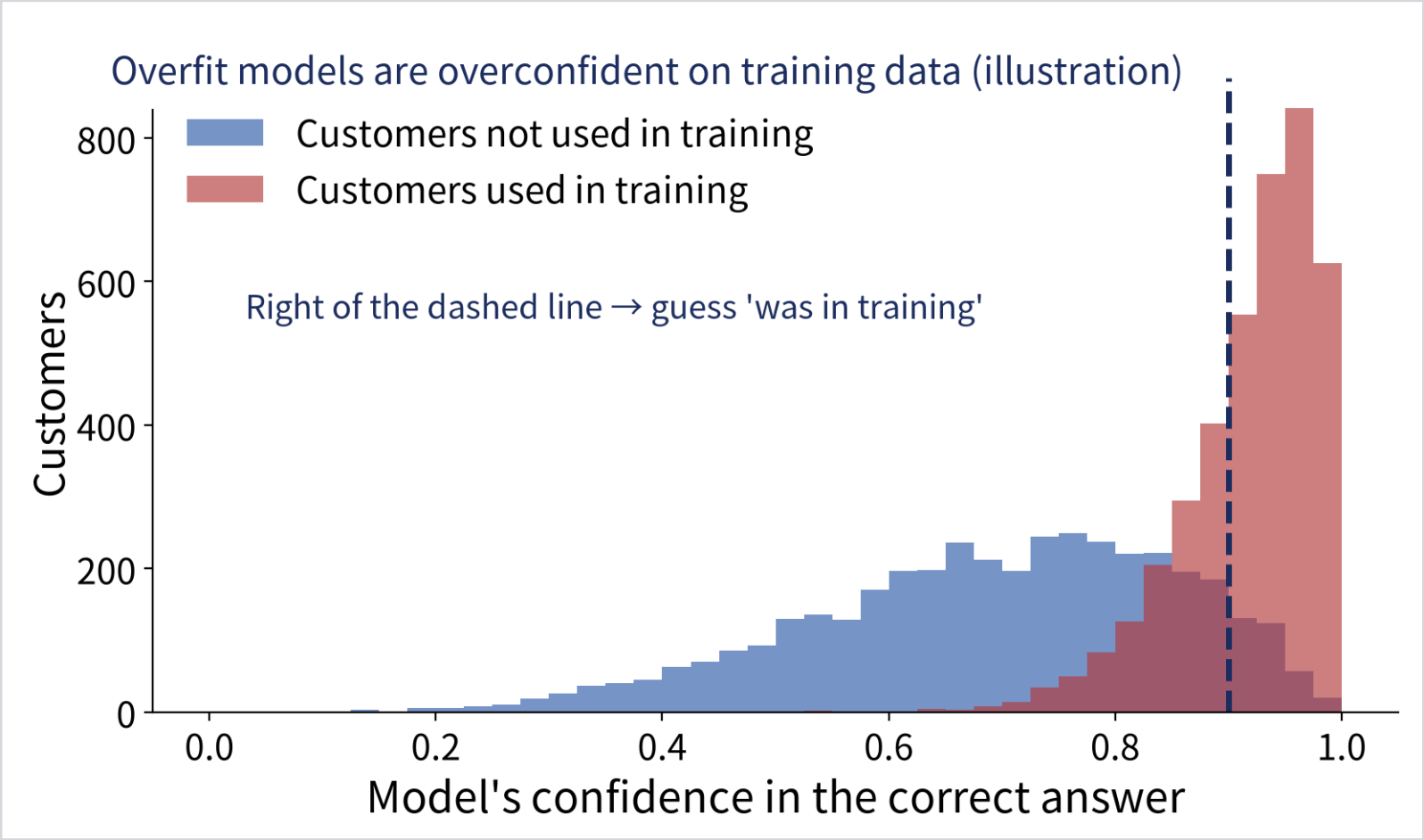
- Larger models memorize more. Alignment does not erase memory; it only masks it
- So training an LLM on data containing personal information requires protection at the training stage

Overfit models visibly recognize the people they were trained on

Illustrative distributions showing how membership inference attacks (Shokri et al. 2017) work

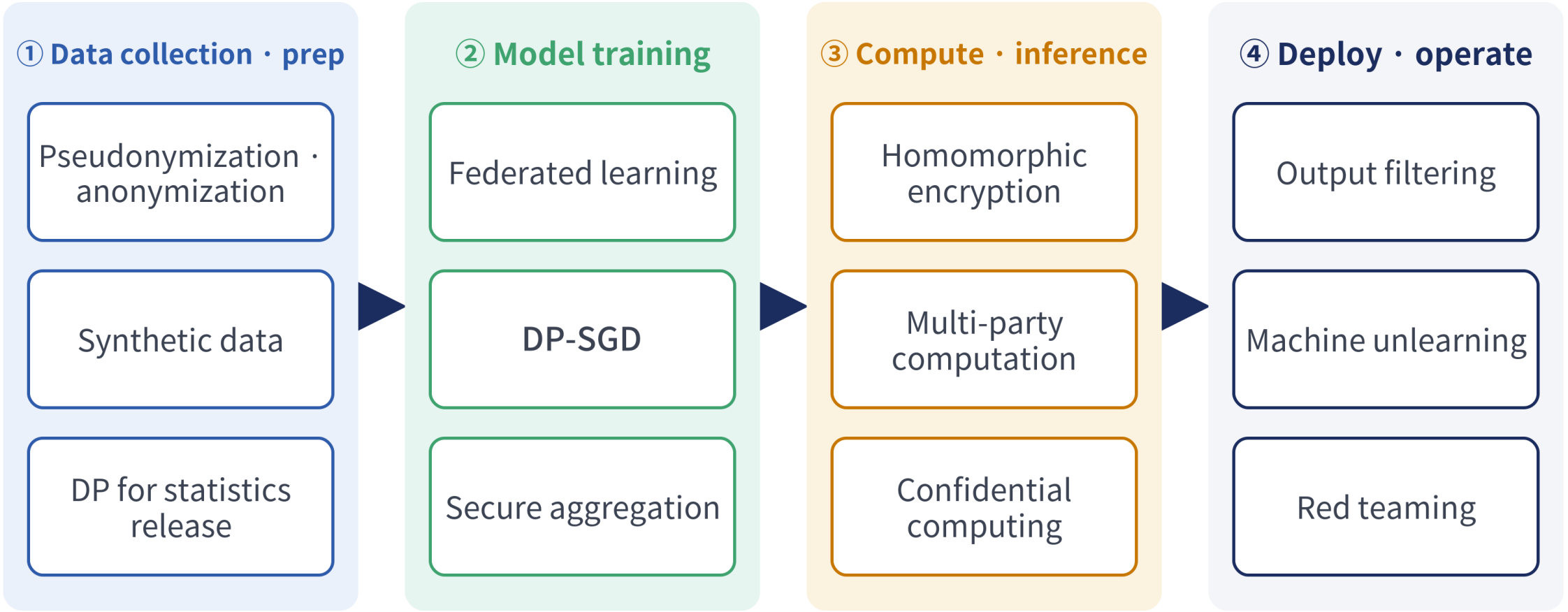
How to read it

- Training customers: high confidence
- New customers: widely spread
- This gap is the leaked information



PPML techniques are spread across four stages of the ML lifecycle

This lecture centers on training (②) and computation (③), and also covers the stages before and after



02

PART 2 · Federated Learning

Federated Learning

Keep data in place and exchange only training results

Federated learning collects training results instead of data

McMahan et al. (2017) FedAvg — the most widely used baseline algorithm today

$$w_{\text{global}}^{t+1} = \sum_{k=1}^{K} \underbrace{\frac{n_k}{n}}_{\text{data share of k}} \underbrace{w_k^{t+1}}_{\text{weights trained by k}}$$

Analogy: a study group across schools

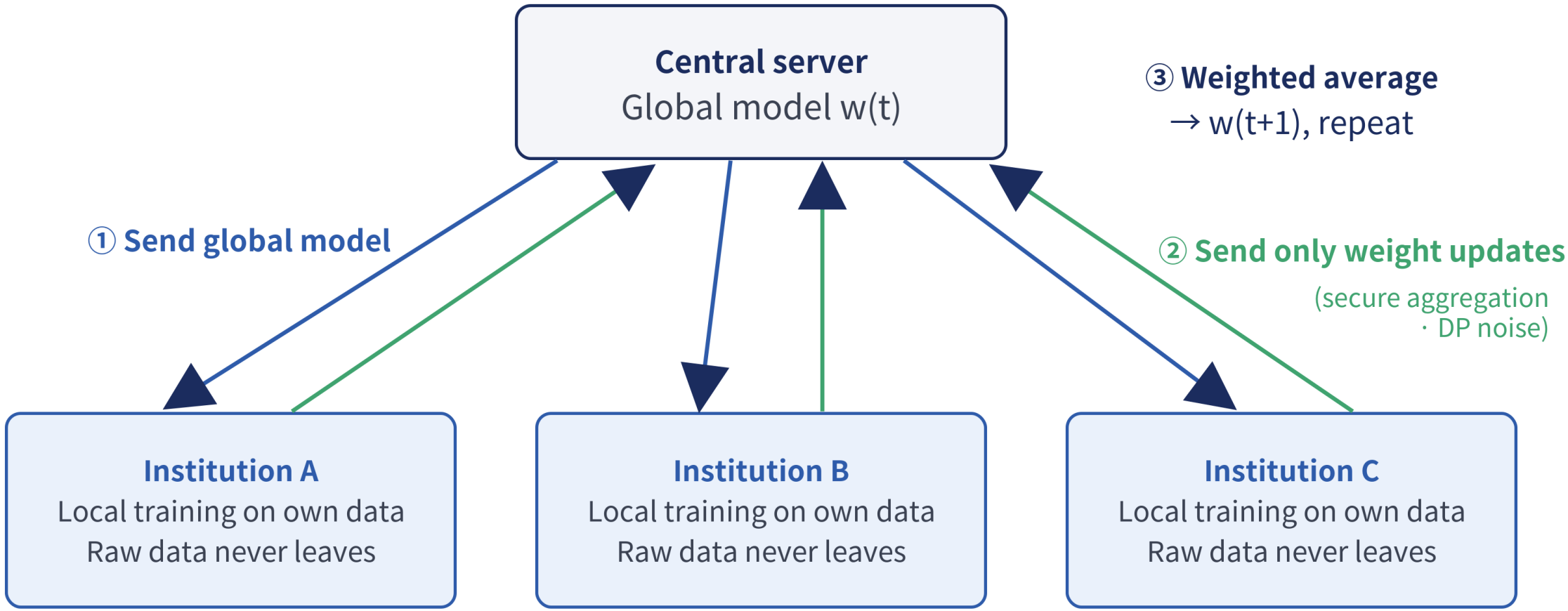
- Exam questions (data) never leave each school
- Only each school's summary notes (model updates) are gathered and merged

What the weighted average means

- Institutions with more data carry more weight in the result
- The server builds the global model without ever seeing the raw data

A federated learning round: distribute, train locally, aggregate

Repeating this round hundreds to thousands of times makes the global model converge



FedAvg needs far fewer communication rounds than FedSGD

FedSGD sends gradients at every step; FedAvg sends weights after several steps

$$w \leftarrow w - \underbrace{\eta}_{\text{learning rate}} \cdot \frac{1}{K} \sum_{k=1}^{K} \underbrace{\nabla L(w; D_k)}_{\text{gradient of k}}$$

Item	FedSGD	FedAvg
What institutions send	A gradient computed once	Weights trained over several steps
Communication frequency	Every training step	Once per round
Weakness	High network cost	Sensitive to data distribution differences (Non-IID)

When participants' data differ, the global model wobbles

FedProx (Li et al. 2020) keeps local models from drifting away from the global model

$$\min_{w} \quad \underbrace{F_k(w)}_{\text{loss of k}} \quad + \quad \underbrace{\frac{\mu}{2}\|w - w^t\|^2}_{\text{penalty for drifting from the global model}}$$

The Non-IID problem

- Data distributions differ across institutions, like pediatrics versus geriatrics
- Each trains toward its own direction, so the average fits none of them

Horizontal vs. vertical federated learning

- Horizontal: same features, different customers, e.g., between banks
- Vertical: same customers, different features, e.g., bank, telecom, and online mall

Federated learning is already in large-scale production

Google keyboard (consumer devices) and the FeTS brain tumor study (cross-hospital)

Google Gboard (Xu et al., ACL 2023)

- Next-word prediction models are trained federatedly on phones
- Devices join training only while charging and on Wi-Fi
- Combines DP-FTRL with secure aggregation
- All neural language models launched since then require DP guarantees

FeTS brain tumor (Nature Comm. 2022)

- MRI of 6,314 patients from 71 institutions on 6 continents
- Asan Medical Center in Seoul was among the participants
- 33% better delineation of the surgically targetable tumor boundary than a public-data model
- Whole-tumor extent improved by 23%

Three internet banks jointly trained a voice phishing model

Federated joint model of the Financial Security Institute and KakaoBank, K bank, and Toss Bank — applied to FDS from July 2026

Up to 205%

vs. each bank's existing model
improvement in detection precision

3 banks → more

to mutual finance, savings banks, and Korea Post
technology-sharing agreement (Dec 2025)

CIKM·NeurIPS

Related research accepted in 2025
at two conferences

Borrowing clues from other banks

- Existing models saw long-established disguised accounts as normal
- They were caught once another bank's 12-hour deposit total was used as well

Why a joint response?

- When one door is shut, fraudsters move to where security is weaker
- A joint model reduces this balloon effect

Federated learning alone does not fully protect personal information

Inversion attacks followed Zhu et al. (2019), Deep Leakage from Gradients

From the gradients the server receives alone, training images can be reconstructed almost exactly

How the attack works

- Start from a dummy input and iteratively adjust it until its gradient matches the real gradient
- When the gradients match, the dummy input resembles the original

Reinforcements

- Differential privacy: add noise to gradients (PART 3)
- Secure aggregation and homomorphic encryption: keep the server from seeing individual gradients (PART 4)

03

PART 3 · Differential Privacy

Differential Privacy

Make results nearly the same whether or not any one person is in the data

Differential privacy mathematically limits one person's influence

Dwork et al. (2006). ε (epsilon) is the privacy loss budget

$$\Pr\left[M(D) \in S\right] \leq e^{\varepsilon} \cdot \Pr\left[M(D') \in S\right]$$

$D,\ D'$

datasets differing by one person

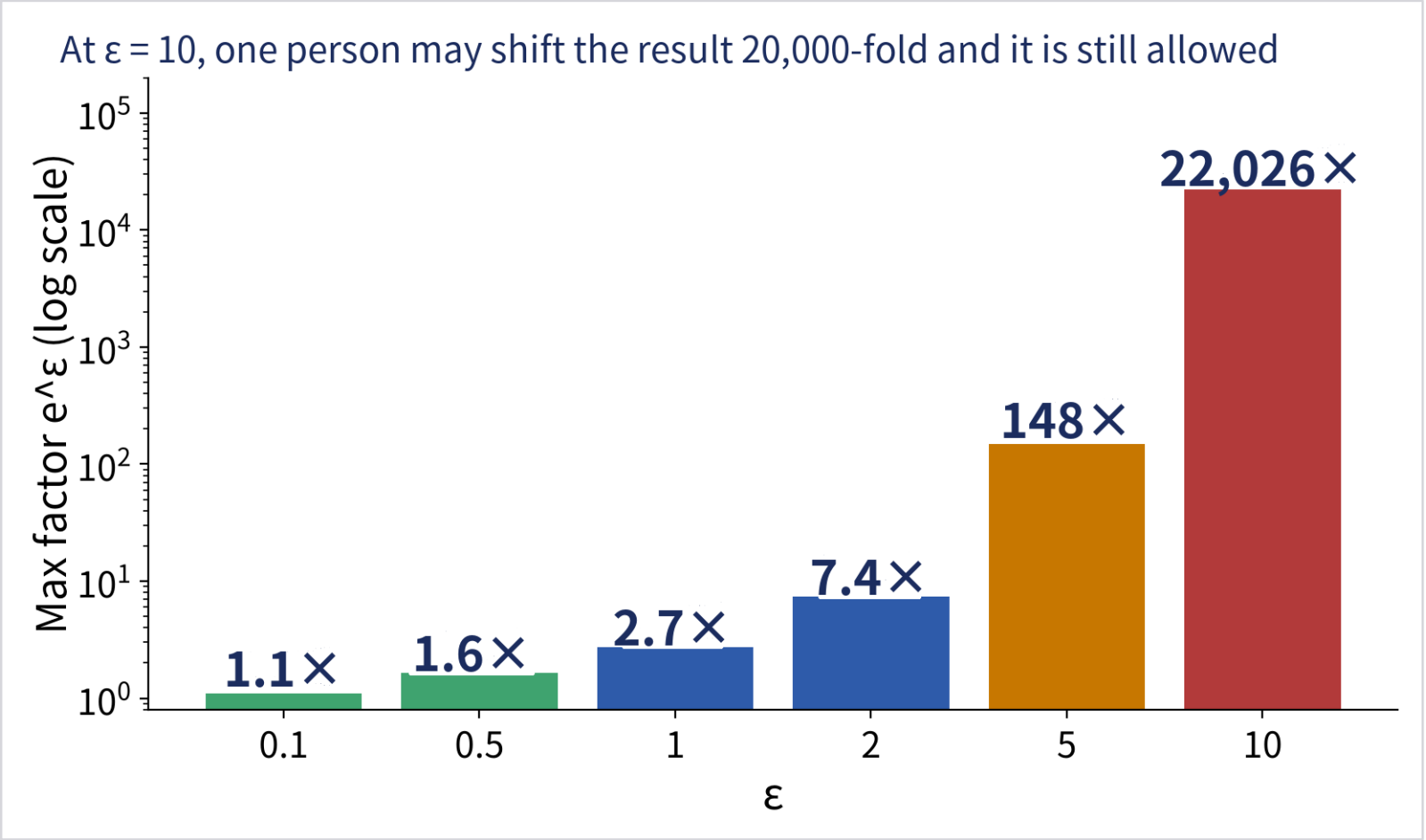
ε value	Meaning	What is visible in financial data
0.1	Very strong protection	Individual customers are not identifiable at all
1	Moderate protection	Roughly patterns at the age-band or regional level emerge
10	Weak protection	Individual characteristics are substantially exposed

ε is the log of the factor by which one person can change the result

e^ε: the maximum ratio of the probability of the same result with and without me in the data

How to read it

- ε 0.1 → 1.1×
- ε 1 → 2.7×
- ε 10 → 22,000×



The coin-flip survey is the oldest DP mechanism

Warner (1965) randomized response — estimates the rate of answers to sensitive questions

$$\Pr[\textbf{yes}] = \tfrac{1}{2}\pi + \tfrac{1}{4} \quad \Longrightarrow \quad \hat{\pi} = 2\hat{p} - \tfrac{1}{2}, \qquad \varepsilon = \ln 3 \approx 1.1$$

Procedure

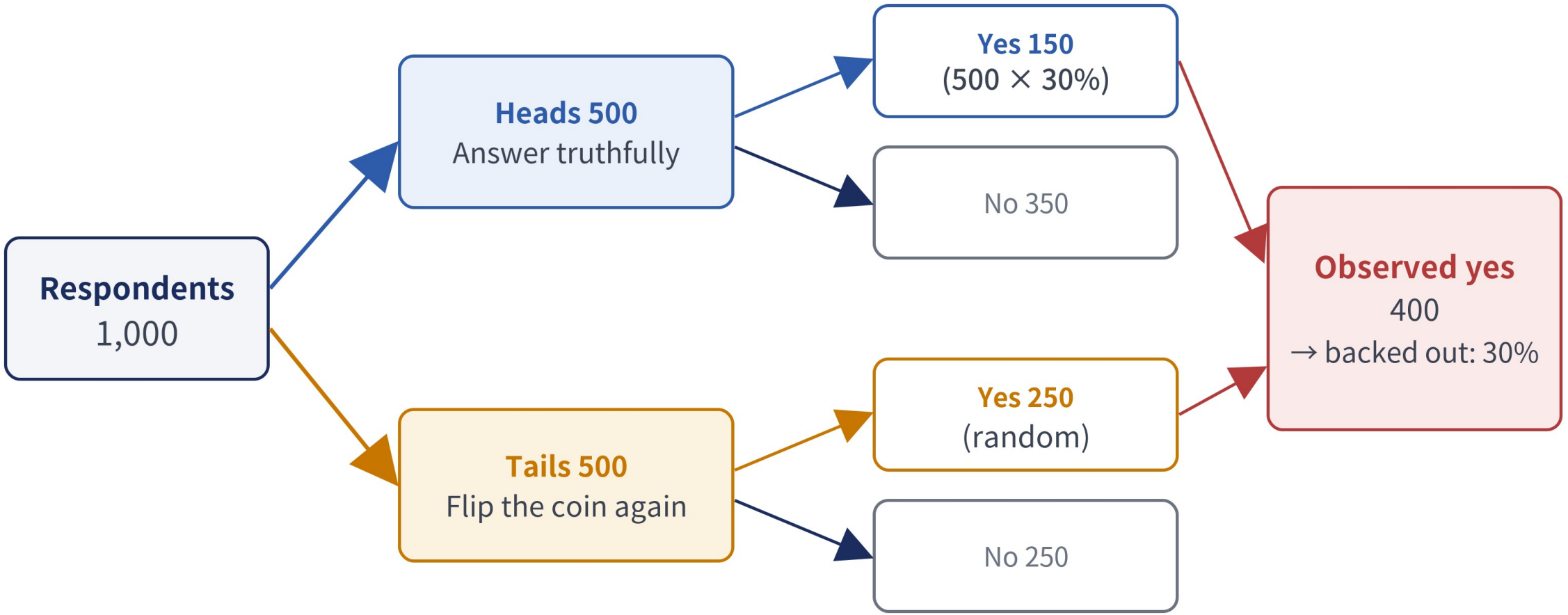
- If the coin lands heads, answer truthfully
- If tails, flip again to decide yes or no
- The surveyor cannot tell whether an individual answer is true

The statistics still survive

- Back out the true rate π from the yes rate p
- Individuals keep deniability while the group rate becomes accurate

If 30% of 1,000 people are truly yes, 400 yes answers come out

The surveyor does not know who among the 400 is truly yes, but backs out 30% from 400 (Workbook W2)



Noise scale is set by sensitivity divided by budget

Sensitivity Δf: the maximum change in a query result when one person changes

$$M(D) = \underbrace{f(D)}_{\text{true value}} + \text{Lap}\left(\underbrace{\frac{\Delta f}{\varepsilon}}_{\text{noise scale = sensitivity / budget}} \right)$$

Counting query example

- One person changes a count by at most 1, so Δf = 1
- With ε = 0.5, the noise scale is b = 2 people

Mean query example

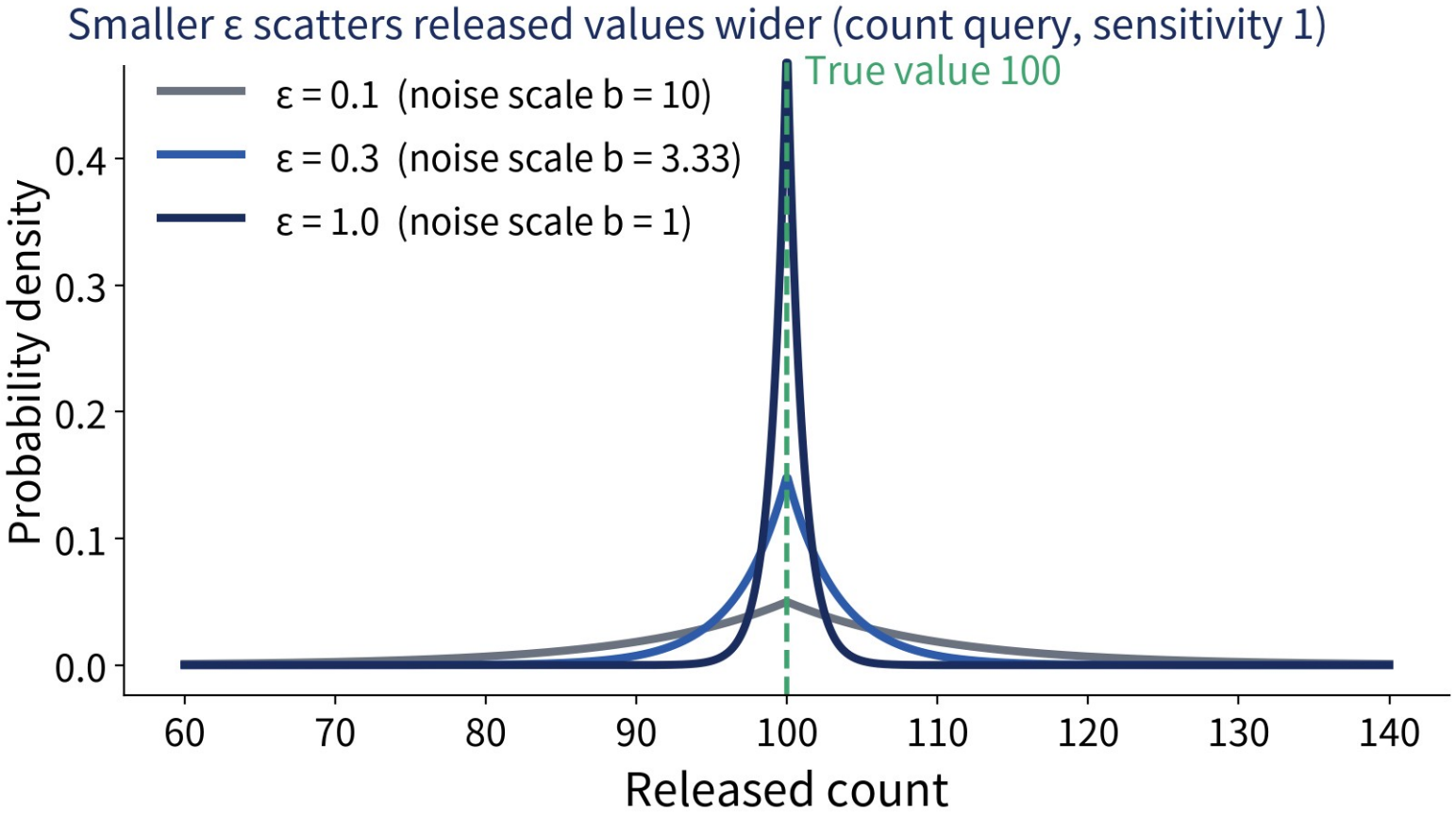
- A wide range, as with salaries, raises sensitivity
- So values are capped first (clipping) to bound sensitivity

The smaller ε, the farther released values scatter from the true value

Distribution of released values after adding Laplace noise to a counting query with true value 100

How to read it

- ε=1: 86% within ±2
- ε=0.1: 86% within ±20
- Trading protection for accuracy



DP-SGD clips per-example gradients and adds noise

Abadi et al. (2016). The budget accumulates as queries and training repeat

$$\tilde{g} = \frac{1}{B}\Big(\sum_{i=1}^{B} \underbrace{\mathrm{clip}(g_i, C)}_{\text{per-example clipping}} + \underbrace{\mathcal{N}(0, \sigma^2 C^2 I)}_{\text{Gaussian noise}}\Big)$$

$$\varepsilon_{\text{total}} \leq \sum_{j=1}^{m} \varepsilon_j$$ (the budget shrinks with every query)

Why two steps?

- Clipping caps one person's influence, and noise calibrated to that cap covers the trace

The US Census Bureau applied DP across the 2020 Census

The trigger was reconstruction attacks that rebuild individual records from published tables

How it was adopted

- Many published tables allow individual records to be rebuilt, so traditional de-identification was replaced
- In tests on 1940 data, ε = 0.25 badly distorted small-area figures
- The demonstration product on 2010 data was evaluated at a total budget of 4.5 (persons 4.0, housing 0.5)
- Each additional table shrinks the remaining budget

Geographic level	Budget share
Nation	20%
State	20%
County	12%
Census tract	12%
Block group · block	12% each

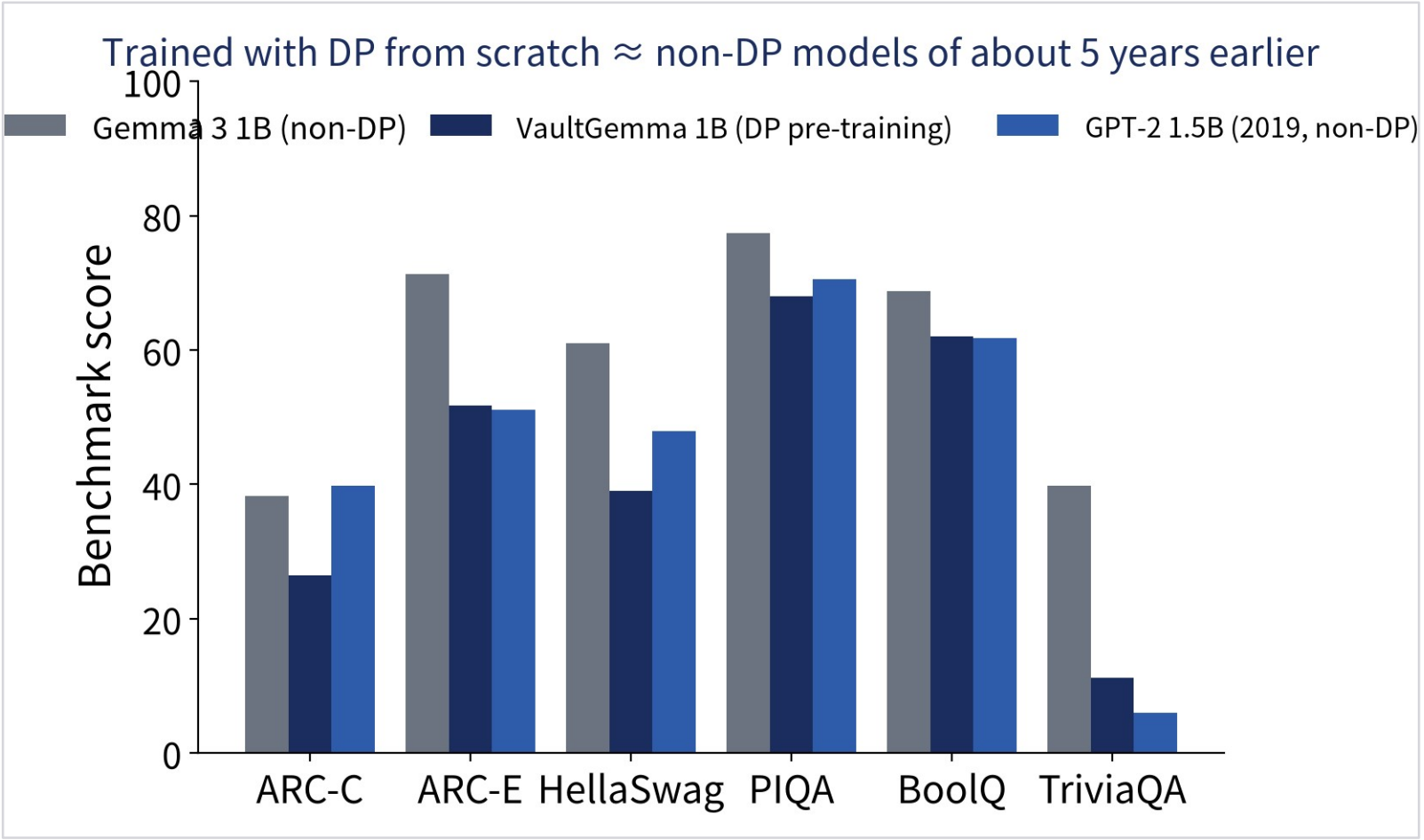
Example allocation by geographic level (Census Bureau briefing, Nov 2020)

Google released an LLM trained with DP from scratch

VaultGemma 1B (Sep 2025) — 1 billion parameters, fully DP pre-trained on the same data as Gemma 2

Key findings

- Performance at the level of 2019's GPT-2
- The gap is narrowing
- Weights and code released



Where DP is applied determines what it protects

Lessons from Apple's practice and the VaultGemma report

Apple's choice

- Since iOS 10 (2016), local DP has been used to collect emoji and typing statistics
- Apple Intelligence improves models with synthetic data and DP-aggregated signals
- Heavy requests go to PCC, which Apple states does not store data

Caveats

- Applying DP only to fine-tuning leaves pre-training data unprotected
- DP protects information that appears once. Information repeated across many documents can still be learned as a pattern

04

PART 4 · Cryptographic Computation

Homomorphic Encryption and Multi-Party Computation

Computing without seeing the data

Computing on ciphertexts gives the same result as on plaintexts

Gentry (2009) presented the first construction of fully homomorphic encryption (FHE)

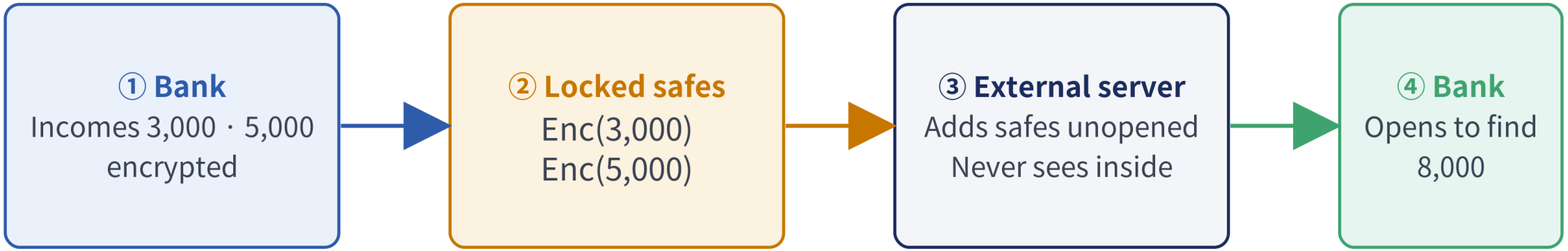
$$\mathrm{Dec}\Big(\,\mathrm{Enc}(x_1)\;\oplus\;\mathrm{Enc}(x_2)\,\Big)\;=\;x_1+x_2$$

Type	Supported operations	Use
Partially homomorphic (PHE)	Only one of + or ×, unlimited	Encrypted sums, vote tallies
Somewhat homomorphic (SWHE)	+ and ×, limited times	Short statistical computations
Fully homomorphic (FHE)	Any computation (needs bootstrapping)	Model inference on ciphertexts

Analogy: adding money while it stays in locked safes. The server never sees inside; only the key holder sees the total

An external server adds two incomes without opening the safes

A setup for outsourcing credit scoring without revealing customer incomes



The server computed the sum without ever seeing a number

Homomorphic encryption reached commercial use first in narrow private lookups

Real deployments in 2025–2026 and remaining limits

Deployments

- Apple Live Caller ID: queries a spam database with the number encrypted
- Apple Enhanced Visual Search: looks up photo landmarks in encrypted form
- Zama: became the first FHE unicorn in June 2025
- Korea's CryptoLab provides homomorphic encryption analytics solutions to financial firms

Remaining limits

- What deployments share: one small query asked of a large database
- General-purpose model training is still hundreds of times slower than plaintext, so it remains hard
- Apple turned it on by default and faced a consent controversy in January 2025

Multi-party computation splits secrets into shares and computes jointly

Secret sharing: a single share reveals nothing about the original value

$$x = (s_1 + s_2 + s_3) \bmod q, \qquad \sum_i x_i = \left(\sum_j \underbrace{T_j}_{\text{sum of shares at server j}} \right) \bmod q$$

Analogy: computing an average salary

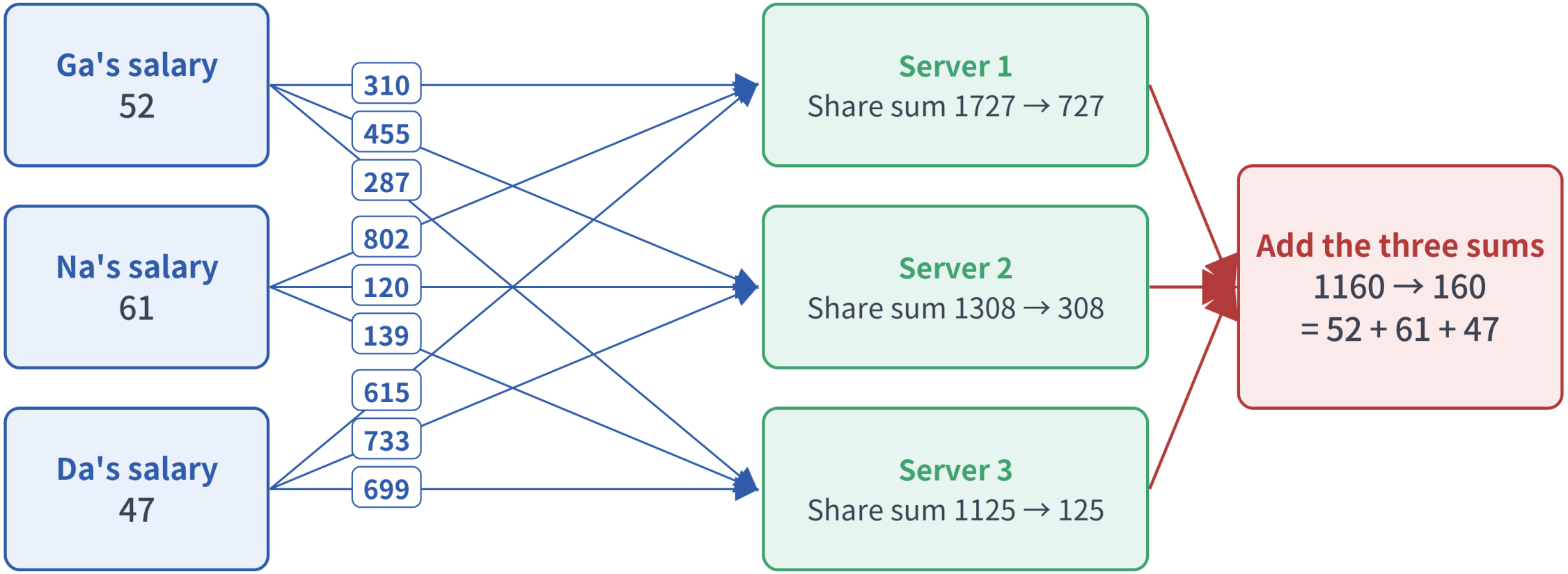
- Each person splits their salary into three shares and sends them to three servers
- Servers add only the shares they received and publish the sums; adding those sums gives the total

Multi-party computation inside federated learning

- Secure aggregation (Bonawitz et al. 2017) is the leading example
- The server learns only the sum of updates, not any individual institution's values

Three servers get the salary total of 160 right while seeing only shares

Each share looks like a random number. Only the remainder of each share sum divided by 1,000 is kept (Workbook W7)



The four techniques protect different things at different costs

In practice, two or more are combined after weighing pros and cons

Item	Federated learning	Differential privacy	Homomorphic encryption	Multi-party computation
Protects	Movement of raw data	One individual's influence	Data during computation	Each participant's input
Analogy	Share only summary notes	Coin in a survey	Computing in locked safes	Puzzle pieces
Cost	Communication cost; weak under Non-IID	Lower accuracy	Very slow computation	Heavy traffic; needs synchronization
Best fit	Many institutions or devices	Large-scale statistics and training	Lookups among a few institutions	Mid-sized joint computation

05

PART 5 · Data and Model Stages

Synthetic Data and Machine Unlearning

Make fakes before training, erase after training

Synthetic data learns from the original to create records that do not exist

There are three main ways to generate it, and three questions to evaluate it

Statistical models

Gaussian copula, etc.

Learn each variable's distribution and the correlations separately, then resample

Tabular customer data

Deep generative models

GAN · VAE · diffusion models

Learn complex patterns through a contest between telling real from fake

Medical images, financial time series

Simulators · LLMs

Rules + agents + language models

Run virtual customers and criminals to produce transactions and text

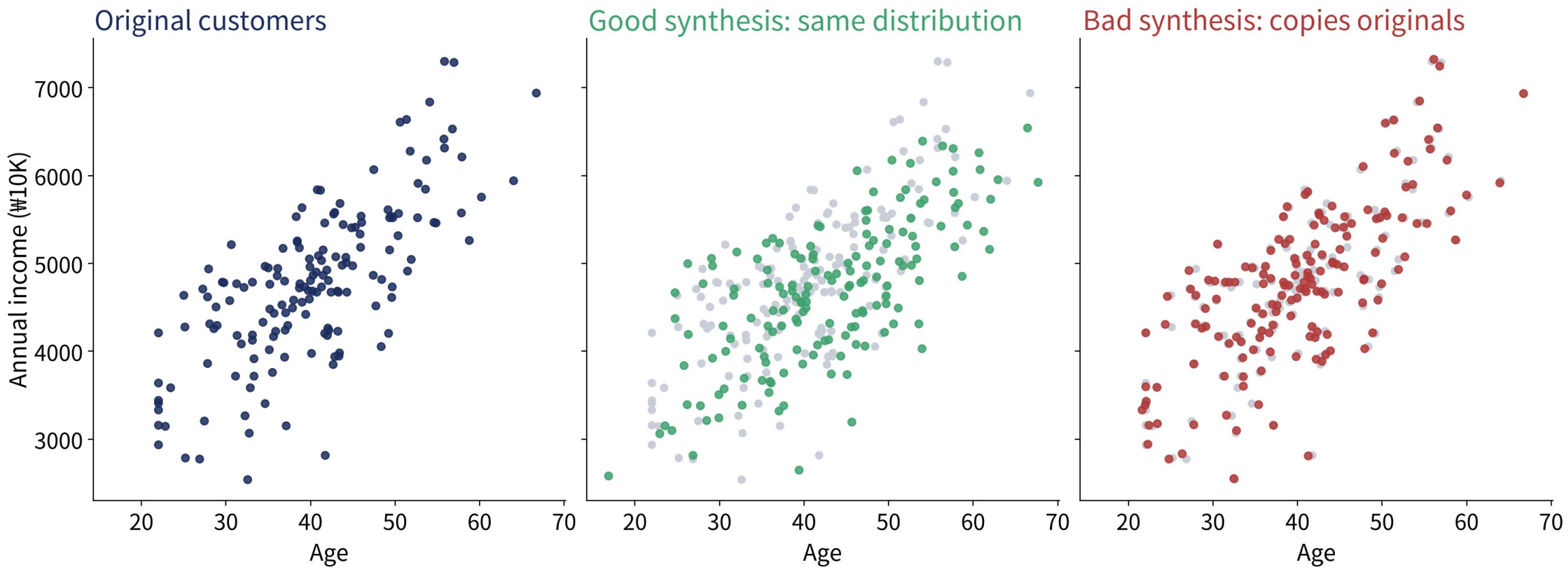
Money laundering, autonomous driving

Three questions for evaluation

- Is the distribution the same as the original? Does a model built on it work well? Is it too close to original records?

Good synthesis resembles the distribution; bad synthesis resembles people

Gray dots are original customers, colored dots synthetic customers — an example drawn with 160 virtual customers



Synthetic data must pass five verification steps to be used safely

Privacy Commission Guide to Generating and Using Synthetic Data (Dec 2024)

① Preparation

Set the purpose and preprocess the original

② Generation

Learn the distribution with statistics, GANs, etc.

③ Validation

Measure safety and utility with metrics

④ Review

A review committee assesses re-identification risk

⑤ Management

Keep to the scope of use and log the history

Key point

- Synthetic data for public release must be validated with a focus on safety and reviewed before it can be used as anonymized information

Overly faithful synthetic data becomes personal information

In 2025, five sector reference models were released, covering healthcare, public safety, retail, finance, and more

Upside: virtual customers

- Real customer: age 35, annual income ₩50M, monthly card spend ₩2M
- Synthetic customer: 33, ₩48M, ₩1.9M — a person who does not exist
- Same patterns, so it can be used for model development and external sharing

Caution: generative models memorize too

- They can nearly copy rare original records
- Check safety with metrics such as distance to the closest original record
- Generating with DP leaves a mathematical guarantee

Synthetic data creates scenes that could never be collected for real

How it is used in autonomous driving, banking, money laundering, and smartphones

Waymo simulation (2019)

- Drove 10 billion miles on virtual roads, about a thousand times its real-road mileage
- Rare and dangerous scenes are varied and replayed countless times

J.P. Morgan AI Research

- Released six synthetic datasets covering money laundering, customer journeys, fraudulent payments, order books, and more
- Overcomes the research barrier of not being able to share real data externally

IBM AMLworld (NeurIPS 2023)

- Real money-laundering labels are rare and incomplete
- Simulating the criminal behavior too gave every transaction a ground-truth label

Apple synthetic email (2025)

- Improves summarization using only synthetic emails and DP signals, without seeing user emails
- Popular Genmoji prompts were also noised so they surface only when hundreds of people use them

Apple asks devices only which synthetic emails resemble real ones

Apple Machine Learning Research (Apr 2025) — selecting training data by combining synthetic data and DP



Real email content never leaves the device. Apple learns only the popularity ranking of synthetic emails

Korea is also pooling financial and medical synthetic data as public assets

Privacy Commission reference models and the Korea Financial Telecommunications & Clearings Institute fraud synthetic data project

Privacy Commission synthetic data reference models

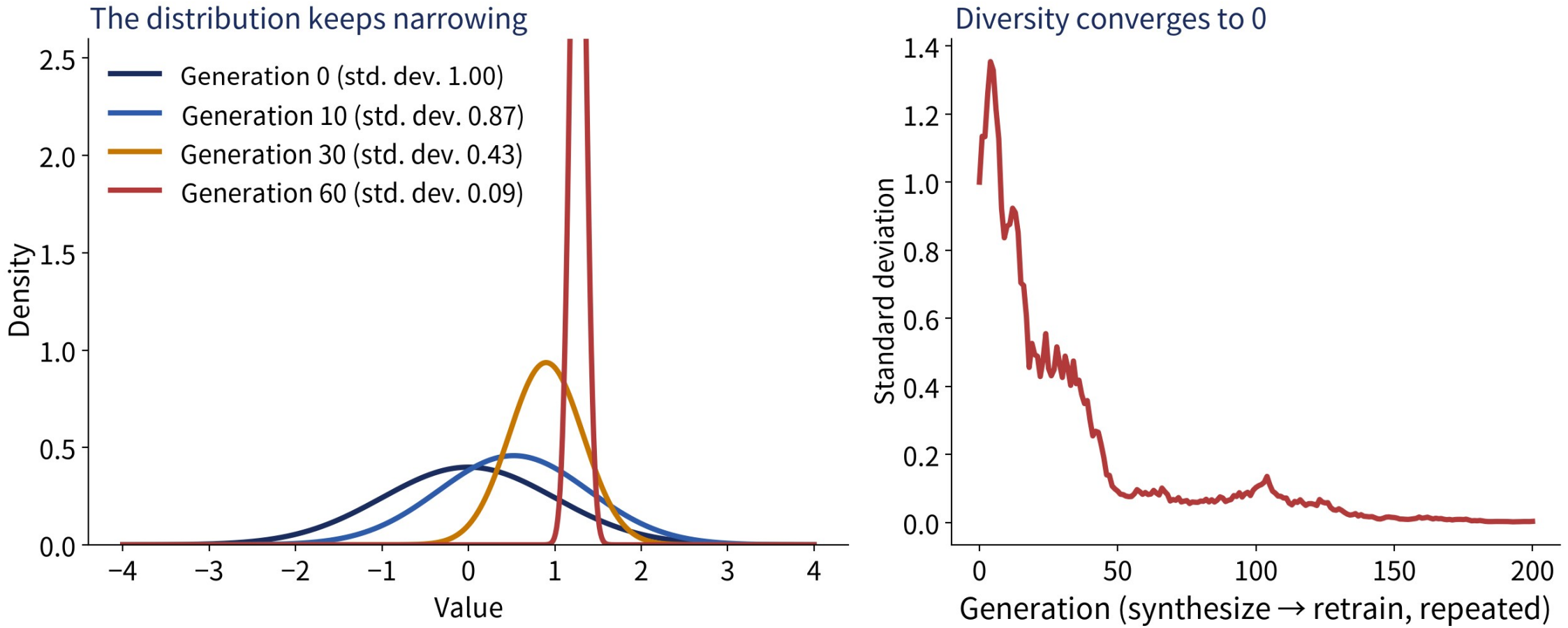
- Five sets, including oral images, released in May 2024. The oral images were generated with GANs
- Five more sets added in 2025 for healthcare, public safety, retail, and finance
- Anyone can download them from the pseudonymized data support platform

Korea Financial Telecommunications & Clearings Institute · Obzen (2025)

- Builds fraud-transaction synthetic data from account transfer, card, and loan scenarios
- Target is 500,000+ records, to be built by December 2025
- Described as the only financial synthetic dataset among 915 public datasets on AI Hub

Training repeatedly on synthetic data alone erases rare cases first

Shumailov et al. (Nature 2024) model collapse — figure is a simulation refitting a normal distribution repeatedly with 30 samples



Synthetic data is not a master key for anonymization

Stadler et al. (USENIX Security 2022) "Synthetic Data — Anonymisation Groundhog Day"

The rarer the customer, the more traces remain in synthetic data, fully exposed to linkage attacks

Findings

- Synthetic data did not guarantee a better privacy–utility balance than traditional anonymization
- Average customers were hidden, but outliers were not

Questions to ask before release

- Did you measure distance to the closest original record?
- Do rare records come out nearly intact?
- Did you test with membership inference attacks?
- Was it generated with DP?

Honoring the right to be forgotten means deleting data from models, too

Retraining is the surest method; LLMs use approximate techniques

$$\theta_{-i} = \arg\min_{\theta} \sum_{j \neq i} L(\theta;\, x_j,\, y_j)$$ **(remove person i and retrain)**

$$\min_{\theta} \; -L\Big(\theta;\, D_{\textbf{forget}}\Big) + \lambda\, L\Big(\theta;\, D_{\textbf{retain}}\Big)$$

The practical choice

- The Privacy Commission chair said bulk deletion of training data is difficult and that output filtering followed by retraining is under discussion
- Whether data was forgotten is rechecked with membership inference attacks

06

PART 6 · Regulation and Practice

Regulatory Change and Financial Applications

The era of proving safeguards before use

Korea has steadily widened the use of personal data for AI training

From Privacy Commission guidelines to a statutory special provision

Period	Content
2024.7	Guide on processing publicly available personal information: AI training on public data allowed under the legitimate interest clause
2024.12	AI Privacy Risk Management Model; Guide to Generating and Using Synthetic Data
2025.8	Guide on processing personal information for developing and using generative AI (4 lifecycle stages)
2026.7	3rd Basic Plan (2027–29): direction to allow training on original video and voice once screening is passed
2026.9	AI special provision amendment promulgated (Act No. 21910), effective Mar 9, 2027
H2 2026	Fines up to 10% of revenue for serious breaches, reduced for security investment

The AI special provision applies only when all three requirements are met

Amended Personal Information Protection Act (passed the National Assembly Aug 20, 2026) — subject to Privacy Commission review and resolution

Three requirements

- AI development is impractical with anonymized or pseudonymized processing
- Safeguards for secure processing are in place
- It serves the public or social interest, and the risk of harming data subjects' interests is markedly low

Set purpose

Define intended uses and foreseeable misuse

Build strategy

Confirm the legal basis for each source

Train & develop

Remove sensitive data and prepare for adversarial attacks

Deploy & manage

Check for training data exposure and guarantee rights

The EU delayed high-risk AI obligations but kept their content

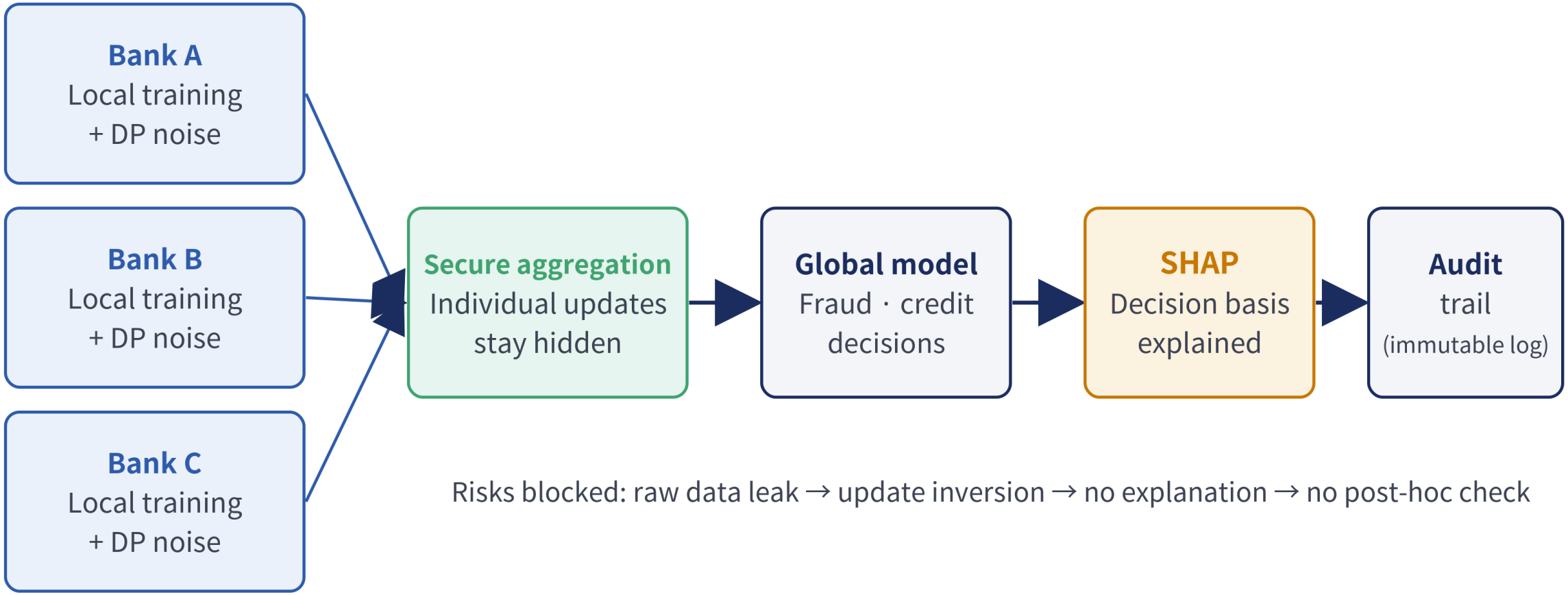
Digital Omnibus on AI (EU 2026/1744), effective Jul 27, 2026

Timing	Content
2025.11.19	Commission proposes the Digital Omnibus (including a clause allowing AI training under GDPR legitimate interest)
2026.8.2	General-purpose AI (GPAI) obligations continue to apply without delay
2026.12.2	New bans on nudification apps and generation of child sexual abuse material
2027.12.2	Obligations for stand-alone high-risk AI (Annex III) apply
2028.8.2	Obligations for high-risk AI embedded in products (Annex I) apply

GDPR Article 22 (right regarding automated decisions) is unchanged. Credit scoring AI must also be explainable

Financial collaboration models bundle protection, explanation, and audit

Example design combining federated learning + DP + secure aggregation + SHAP explanations + audit logs



Risks blocked: raw data leak → update inversion → no explanation → no post-hoc check

Choose the combination of techniques by the nature of the task

Start by asking where the data lives and who must not see what

Task	Recommended combination	Reason
Cross-institution fraud detection	Federated learning + secure aggregation	Share patterns without moving data
Joint credit scoring development	Federated learning + DP	Keep individual contributions out of the model
External lookup of sensitive data	Homomorphic encryption	The counterparty cannot see the query
Regulatory reporting and statistics release	Differential privacy	Prevents reconstruction from published statistics
Outsourced model development	Synthetic data (+ DP)	The original is never handed over

Technology is not enough; an accountability framework must come with it

Privacy Commission generative AI guide and the Financial Security Institute's AI security verification

CPO-led governance

- The CPO oversees the lawfulness and safety of the entire AI process
- Privacy impact assessments and red teaming assess risk continuously
- Works with the CAIO and CISO and applies Privacy by Design (PbD) from the planning stage

Financial AI security verification

- A third party checks for data poisoning and model poisoning attacks
- Model extraction, model inversion, and evasion attacks are also tested with simulated attacks
- Generative AI designated as an innovative financial service is assessed on security for its network separation exemption

What should be judged in the following situations?

Focus on explaining the reasoning rather than the right answer

Q1	Three banks build a joint fraud detection model. Is federated learning alone enough, and what else should be added?	**Technique mix**
Q2	Raising ε from 1 to 8 boosted accuracy sharply. What was lost, and who should make this decision?	**Privacy budget**
Q3	A customer requested deletion, but retraining takes three weeks. What will you do in the meantime?	**Right to be forgotten**
Q4	You plan to share customer data externally with only names removed, keeping age, dong, and sex. What is the problem?	**Re-identification**

PPML is how to gain both data utility and trust

Revisiting the three messages

1

Protection is complete only when memory is blocked

Federated learning protects raw data, but adding DP and secure aggregation is what stops inversion and extraction.

2

Protection and accuracy are traded through a budget

Setting ε is not a technical decision but a management decision on risk appetite.

3

Provable safeguards are a competitive edge

The AI special provision, the guides, and the EU regulation all require documented safeguards.

Next step — compute FedAvg, randomized response, Laplace noise, and secret sharing by hand in the workbook

Sources for re-identification and synthetic data

Basis for the supplementary cases in PART 1 and PART 5

Topic	Source
ZIP code, birth date, sex; Governor Weld	Sweeney (2000, 2002); literature review on data re-identification
Netflix, AOL, New York taxis	Narayanan·Shmatikov(2008); NYT(2006); Tockar(2014)
Payments, location, demographics	de Montjoye et al. (Science 2015, Sci. Rep. 2013); Rocher et al. (Nat. Comm. 2019)
Synthetic data cases	Waymo (2019); J.P. Morgan AI Research; Altman et al. (NeurIPS 2023); Apple MLR (2025)
Synthetic data risks	Shumailov et al. (Nature 2024); Stadler et al. (USENIX Security 2022)
Korean synthetic data	Privacy Commission reference models (2024–25); Finance Scope (Jul 9, 2025)

Key sources

Basis for figures and cases in the main text

Topic	Source
FedAvg·Gboard	McMahan et al. (2017) AISTATS; Xu et al. (2023) ACL Industry
FeTS brain tumor	Pati et al. (2022) Nature Communications 13:7346
Korean voice phishing joint model	Financial Security Institute release (Jun 24, 2026); Byline Network and Yonhap News reports
Training data extraction	Nasr et al. (2025) ICLR; gradient inversion: Zhu et al. (2019) NeurIPS
DP, census, VaultGemma	Dwork et al. (2006); US Census Bureau materials; VaultGemma technical report (2025)
Korea and EU regulation	Privacy Commission guides (2024–25), amended Privacy Act (2026), EU 2026/1744